

Final Report

Executive Summary

This project evaluates how a fictional company can defend an internal AI assistant against indirect prompt injection while keeping the work defensive, lab-only, and based entirely on synthetic data.

Project Context / Organizational Scenario

The organization uses an internal assistant to read emails, search internal documents, summarize findings, draft replies, and flag items for review. The security concern is that retrieved content may contain hidden instructions that attempt to override user intent or disclose sensitive information.

Scope And Assumptions

- Offline-first evaluation with a deterministic mock model.
- Optional OpenAI-compatible backend kept behind configuration and not required for grading.
- All tools are simulated; no real sends, exports, commands, or public target testing occur.

Asset Inventory

- Synthetic email and document corpus
- Baseline assistant pipeline
- Defended assistant pipeline
- Evaluation harness and evidence outputs
- Report and presentation artifacts

Threat Model

Primary threats include instruction override, data exfiltration attempts, summary poisoning, tool misuse, and approval-bypass attempts embedded in retrieved content.

Baseline Findings

The baseline merges user requests with retrieved content in a single prompt and executes the resulting action with minimal control checks, making it a useful before-state for defensive comparison.

Defensive Controls Proposed Or Implemented

- Source labeling for trusted, untrusted, and unknown content
- Prompt separation between system rules, user intent, and retrieved data
- Simulated tool allowlist with blocked unsupported actions
- Output validation for leakage, hijack phrases, and approval bypass
- Simulated human approval gate for high-risk drafts

Validation / Evaluation Results

- Baseline attack success rate: 0.700
- Defended attack success rate: 0.000
- Baseline benign task success rate: 1.000
- Defended benign task success rate: 1.000
- Baseline leakage rate: 0.190
- Defended leakage rate: 0.000
- Baseline blocked unsafe action rate: 0.100
- Defended blocked unsafe action rate: 1.000

Before Vs After Comparison

The defended assistant reduced attack success and leakage to zero in the current offline scenario set while preserving benign task success. The baseline remained intentionally vulnerable and demonstrated why layered controls are necessary.

Residual Risk

- Heuristic validators can miss novel phrasing.
- Source labels are synthetic and do not solve enterprise provenance problems by themselves.
- The optional external backend may behave differently from the deterministic mock path.

Lessons Learned

- Prompt separation alone is not enough without policy and validation.
- Approval gates matter most when sensitive content intersects with outbound communication.
- A clean baseline-vs-defended comparison makes defensive value legible for stakeholders.

References

1. Google DeepMind. Lessons from Defending Gemini Against Indirect Prompt Injections. arXiv, 2025.

Appendix With Supporting Evidence

- `evidence/sample\_outputs/comparison\_summary.json`
- `evidence/sample\_outputs/comparison.md`
- `evidence/sample\_outputs/metrics.png`
- `artifacts/validation\_table.md`